

Security+ 1.2 · Physical Security

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 1.2 — Physical Security (8:17)** ·

[Vídeo no YouTube ↗](#)

Resumo da Aula: Barreira física ao datacenter/escritório: guard shack, bollards, muros (preventivo); badge/RFID/NFC reader + mantrap/vestibular (impede piggybacking); HVAC e fire suppression (proteção à infra); câmeras/alarmes (detectivo).

Highlights que a prova cobra

- Mantrap/vestibular: 2 portas, só se abre uma quando a outra fecha — impede tailgating
- Fire suppression: agente limpo (FM-200) > água em datacenter
- Hot/cold aisle + HVAC = temperatura controlada

Dicas de prova & Cenários Típicos

- 'prevents tailgating/piggybacking' = mantrap / vestibular control
- 'fire suppression agent that doesn't damage equipment' = FM-200/clean agent

Cenário clássico de exame: Cenário típico: 'empresa impede que uma pessoa entre na sala de servidores atrás de outra' → mantrap/vestibular.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 1.2)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Physical Security) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Criptografia Simétrica (AES-256, ChaCha20):** Usa uma única chave idêntica para cifrar e decifrar. Excelente para confidencialidade de grandes volumes (BitLocker, banco de dados, túneis VPN). **Atenção de prova:** cifras simétricas NÃO oferecem não-repúdio quando a chave é compartilhada.
- **Criptografia Assimétrica (RSA, ECC, Ed25519):** Usa par de chaves matemáticas: a Chave Pública é distribuída livremente; a Chave Privada é mantida em segredo absoluto pelo titular. Assinar o hash com a chave privada garante **Não-repúdio e Autenticidade**. Cifrar com a chave pública do destinatário garante **Confidencialidade**.
- **Hashing (SHA-256, SHA-3) vs. HMAC:** Hash puro é função matemática unidirecional sem chave, garantindo apenas integridade (qualquer um pode recalculá-lo de um dado adulterado). O HMAC combina hash com chave simétrica secreta, provendo integridade e autenticação mútua entre sistemas conhecidos.
- **TSA (Time Stamping Authority - RFC 3161) e LTV:** Entidade confiável que assina o hash com data/hora auditada, provando o momento exato em que o documento existiu e garantindo validação de longo prazo (LTV) mesmo após a expiração de certificados.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Hash puro NÃO fornece não-repúdio.
- AES com chave compartilhada destrói o não-repúdio.
- Políticas em papel e termos de adesão são controles puramente administrativos; não bloqueiam ataques em tempo de execução.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Um atacante usa RFID para clonar crachás de funcionários e acessar áreas restritas. Que tipo de ataque físico é esse?

- A) Tailgating**
- B) Shoulder surfing**
- C) Clonagem de credenciais**
- D) Dumpster diving**

2. Sistema-isca que finge ser vulnerável pra atrair e estudar atacantes:

- A) Honeypot**
- B) DMZ**
- C) Bastion host**
- D) Jump box**

3. Cenário corporativo (Physical Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Mantrap/vestibular: 2 portas, só se abre uma quando a outra fecha — impede tailgating'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Substituir controles técnicos preventivos por termos de adesão informais**
- C) Permitir acesso compartilhado entre administradores com credenciais genéricas**
- D) Implementar a solução correspondente: Mantrap/vestibular: 2 portas, só se abre uma quando a outra fecha — impede ...**

4. Cenário corporativo (Physical Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Fire suppression: agente limpo (FM-200) > água em datacenter'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Implementar a solução correspondente: Fire suppression: agente limpo (FM-200) > água em datacenter...**
- C) Substituir controles técnicos preventivos por termos de adesão informais**
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas**

5. Cenário corporativo (Physical Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Hot/cold aisle + HVAC = temperatura controlada'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Hot/cold aisle + HVAC = temperatura controlada...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Physical Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'prevents tailgating/piggybacking' = mantrap / vestibular control'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'prevents tailgating/piggybacking' = mantrap / vestibular control...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Physical Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'fire suppression agent that doesn't damage equipment' = FM-200/clean agent'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'fire suppression agent that doesn't damage equipment' = FM-200/clean agent...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Physical Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'empresa impede que uma pessoa entre na sala de servidores atrás de outra' → mantrap/vestibular.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Cenário típico: 'empresa impede que uma pessoa entre na sala de servidores ...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Physical Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Mantrap/vestibular: 2 portas, só se abre uma quando a outra fecha — impede tailgating'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Mantrap/vestibular: 2 portas, só se abre uma quando a outra fecha — impede ...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Physical Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Fire suppression: agente limpo (FM-200) > água em datacenter'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Fire suppression: agente limpo (FM-200) > água em datacenter...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) C — Clonagem de credenciais.

✓ **Por que está certa:** Clonagem de credenciais RFIDs permite criar cópias não autorizadas de crachás/cartões de acesso, permitindo entrada física não autorizada em instalações.

✗ **Por que as outras estão erradas:**

- *Tailgating*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Shoulder surfing*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Dumpster diving*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) A — Honeypot.

✓ **Por que está certa:** Honeypot é armadilha: parece alvo real, serve pra detectar/estudar o atacante. Honeynet = rede de honeypots.

✗ **Por que as outras estão erradas:**

- *DMZ*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Bastion host*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Jump box*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) D — Implementar a solução correspondente: Mantrap/vestibular: 2 portas, só se abre uma quando a outra fecha — impede

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Physical Security): Mantrap/vestibular: 2 portas, só se abre uma quando a outra fecha — impede tailgating.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: Fire suppression: agente limpo (FM-200) > água em datacenter....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Physical Security): Fire suppression: agente limpo (FM-200) > água em datacenter.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para

detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: Hot/cold aisle + HVAC = temperatura controlada....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Physical Security): Hot/cold aisle + HVAC = temperatura controlada.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: 'prevents tailgating/piggybacking' = mantrap / vestibular control....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Physical Security): 'prevents tailgating/piggybacking' = mantrap / vestibular control.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: 'fire suppression agent that doesn't damage equipment' = FM-200/clean agent....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Physical Security): 'fire suppression agent that doesn't damage equipment' = FM-200/clean agent.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: Cenário típico: 'empresa impede que uma pessoa entre na sala de servidores

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Physical Security): Cenário típico: 'empresa impede que uma pessoa entre na sala de servidores atrás de outra' → mantrap/vestibular..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: Mantrap/vestibular: 2 portas, só se abre uma quando a outra fecha — impede

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Physical Security): Mantrap/vestibular: 2 portas, só se abre uma quando a outra fecha — impede tailgating.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Fire suppression: agente limpo (FM-200) > água em datacenter....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Physical Security): Fire suppression: agente limpo (FM-200) > água em datacenter.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.